Sessions

Agenda

- **Sessions**
- First-party cookies
- Third-party cookies
- Example from project 2

What are sessions?

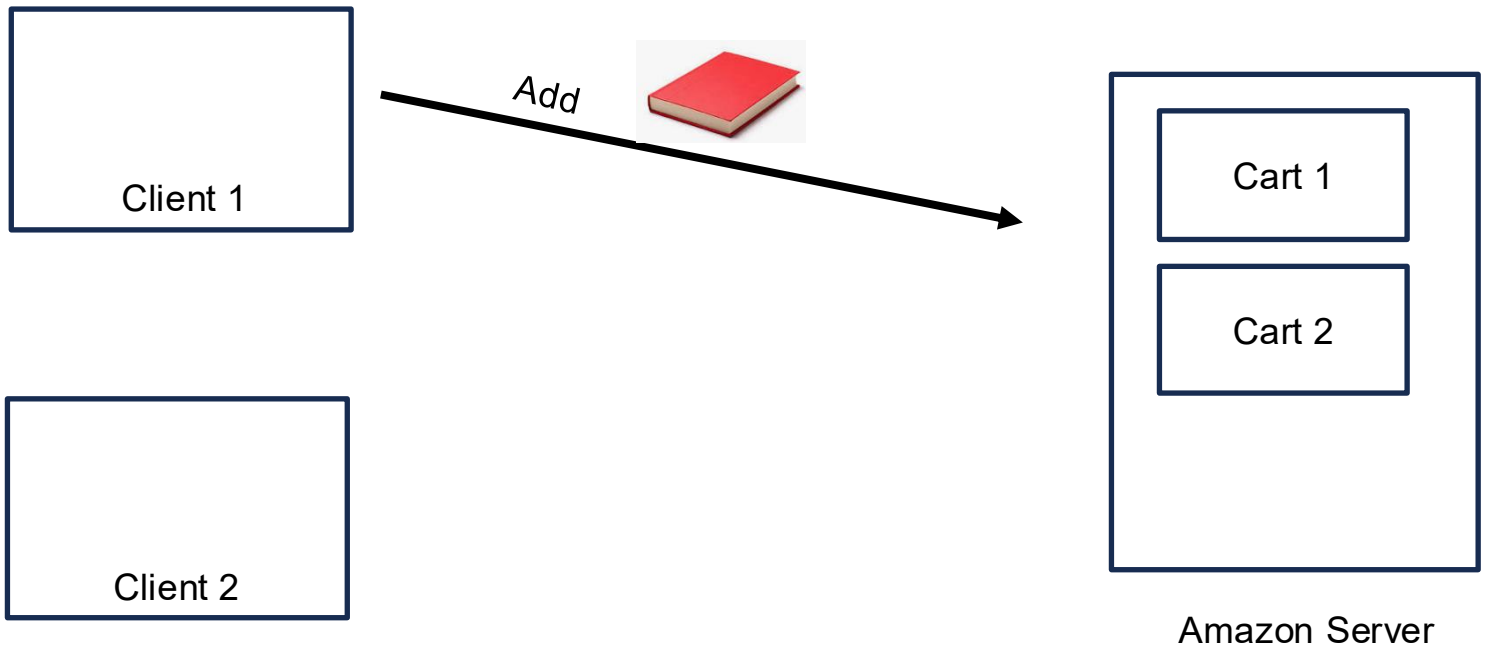
- How a website knows multiple requests come from the same user
- Example: login
  - Log in on one web page
  - Site remembers you are logged in on other pages
- Example: shopping cart
  - Cart persists across pages

Problem: Stateless HTTP

- HTTP is **stateless**
  - No memory between requests or connections

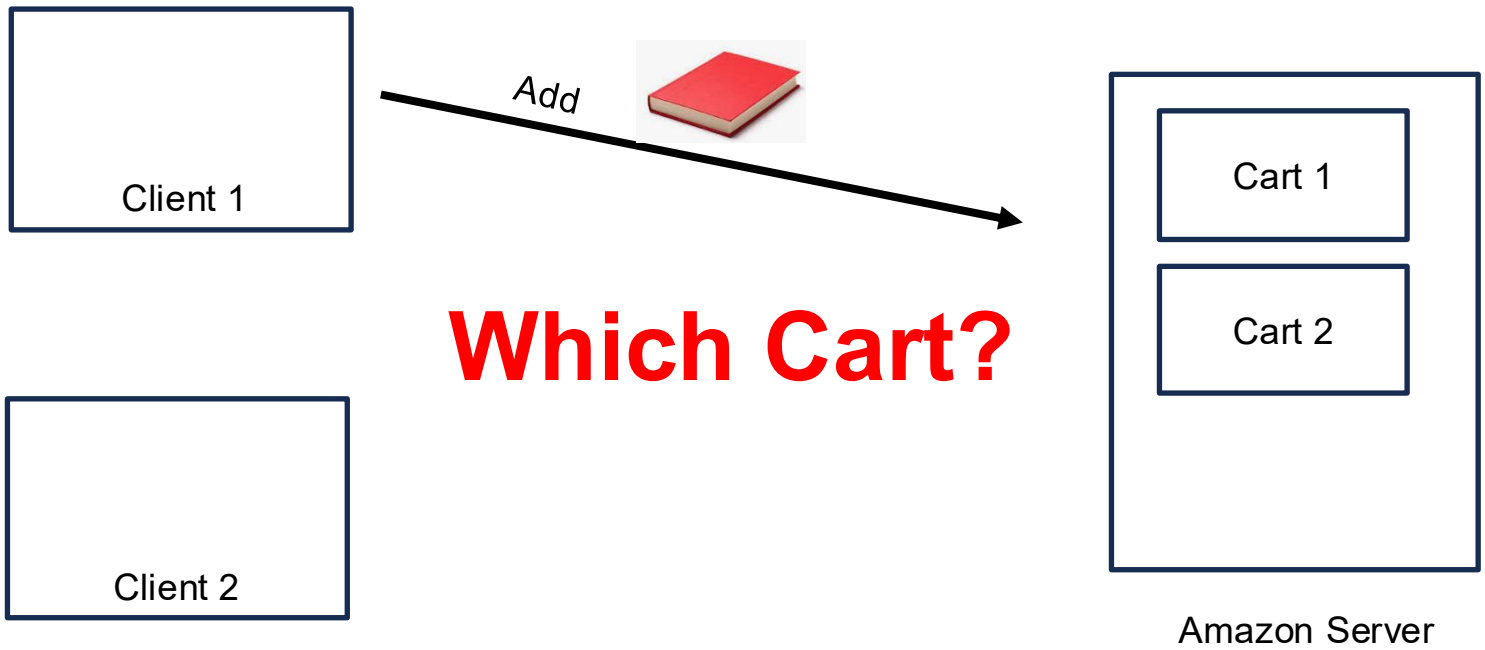
What are sessions?

- How a website knows multiple requests come from the same user



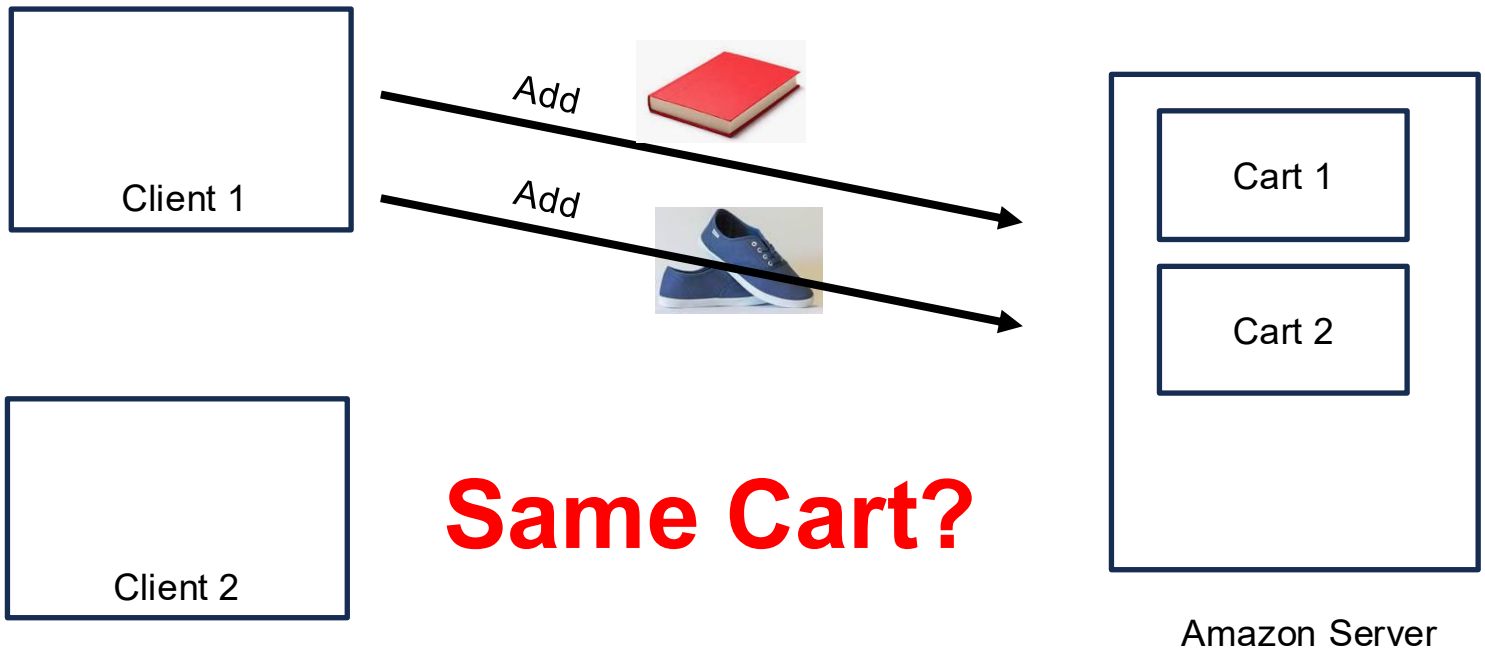
What are sessions?

- How a website knows multiple requests come from the same user



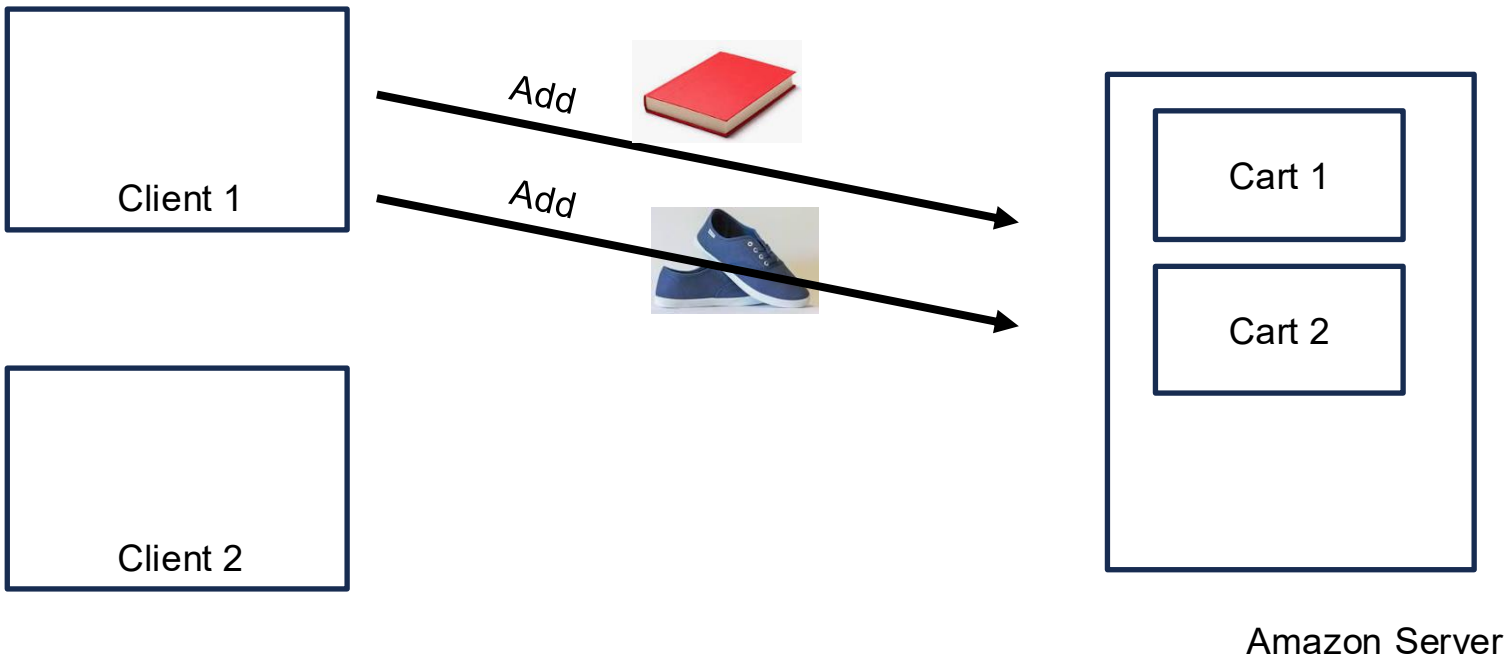
What are sessions?

- How a website knows multiple requests come from the same user



What are sessions?

- How a website knows multiple requests come from the same user



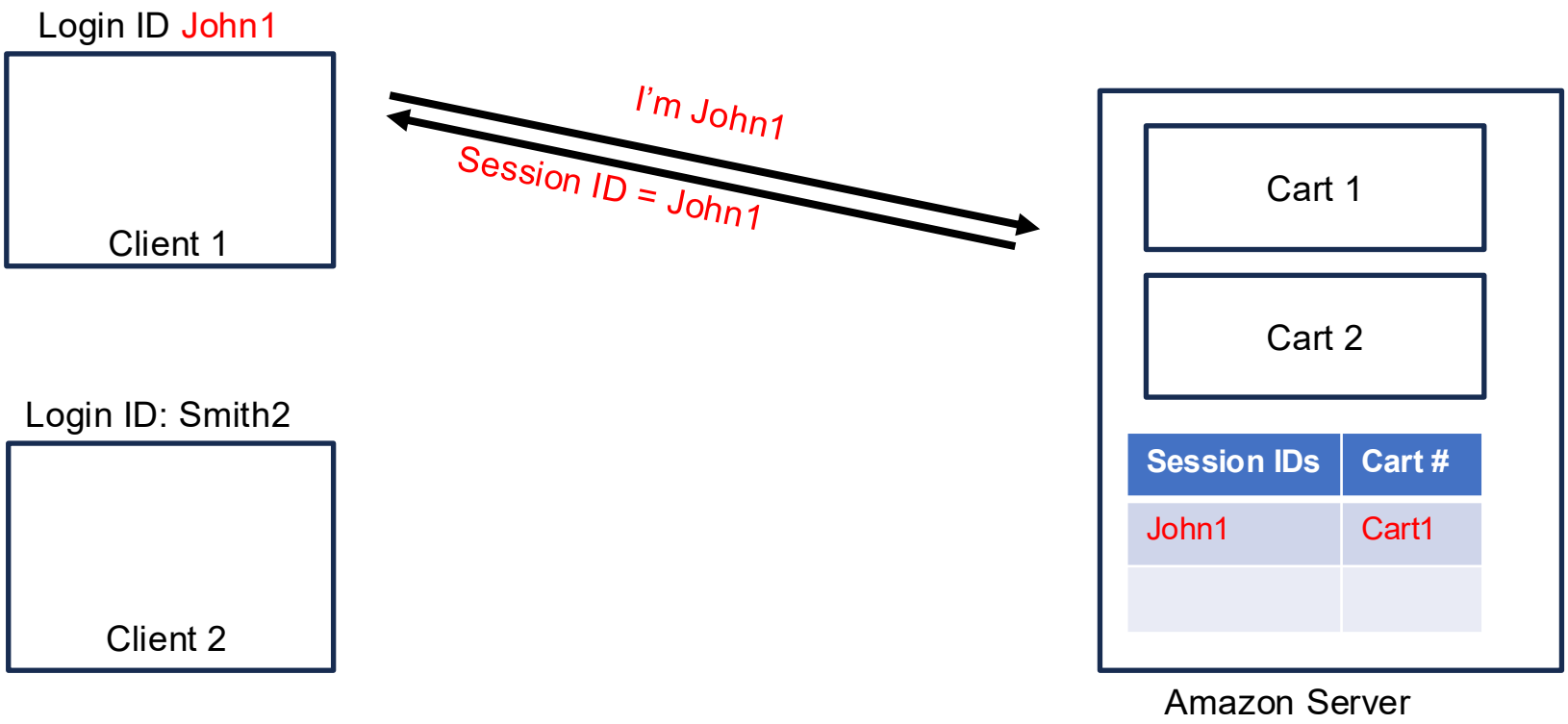
Can we use the HTTP request?

Problem: Stateless HTTP

- HTTP is **stateless**
  - No memory between requests or connections
- Solution: Include extra “ID” data with every HTTP request
  - Usually implemented with *cookies*

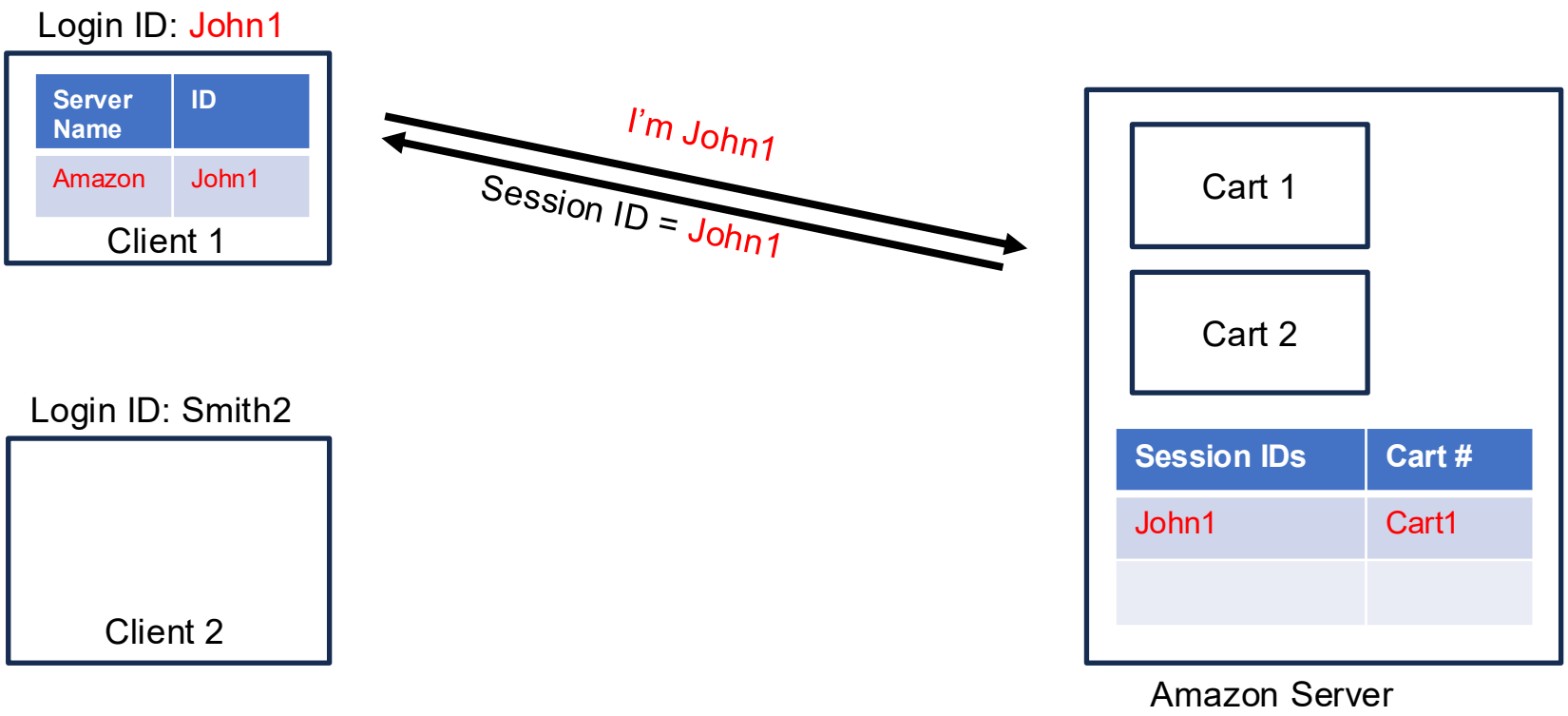
What are sessions?

- How a website knows multiple requests come from the same user



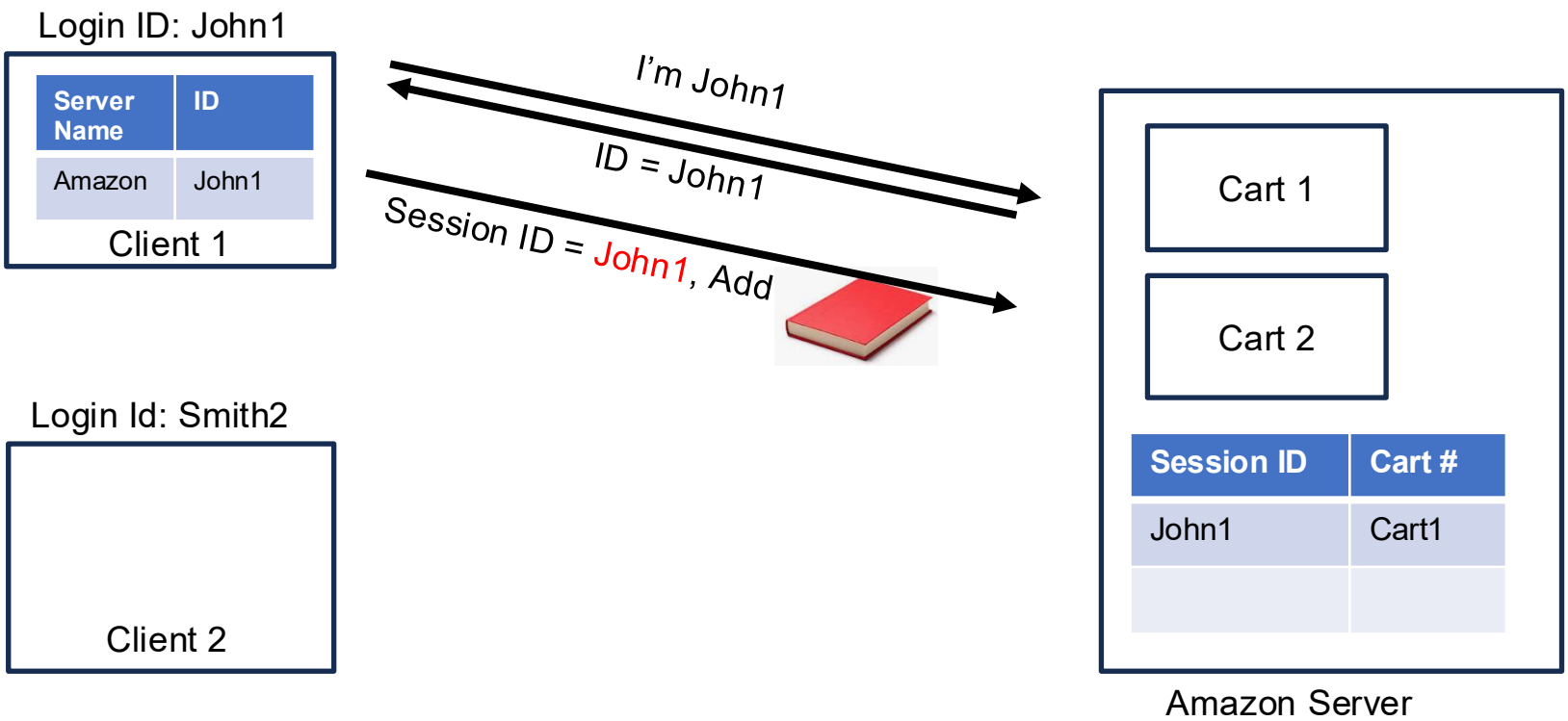
What are sessions?

- How a website knows multiple requests come from the same user



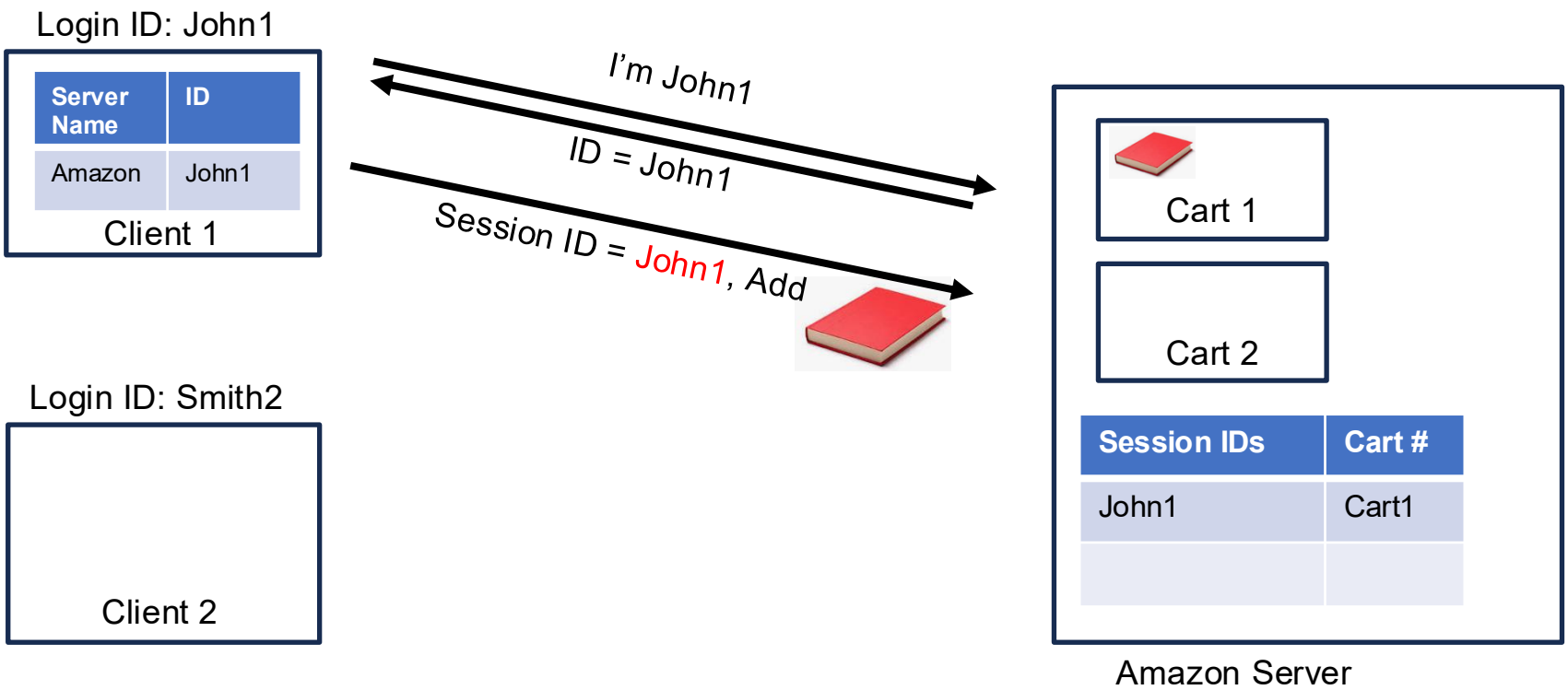
What are sessions?

- How a website knows multiple requests come from the same user



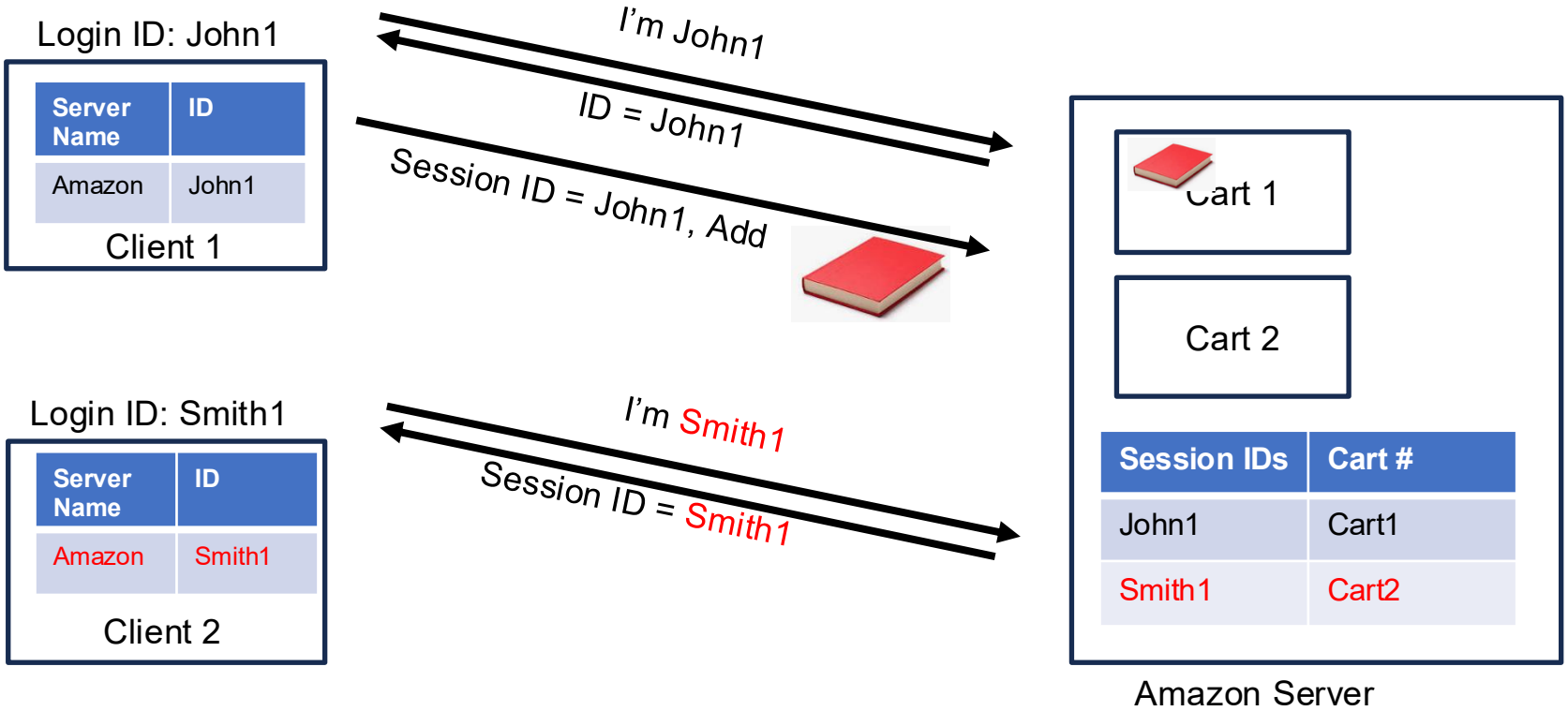
What are sessions?

- How a website knows multiple requests come from the same user



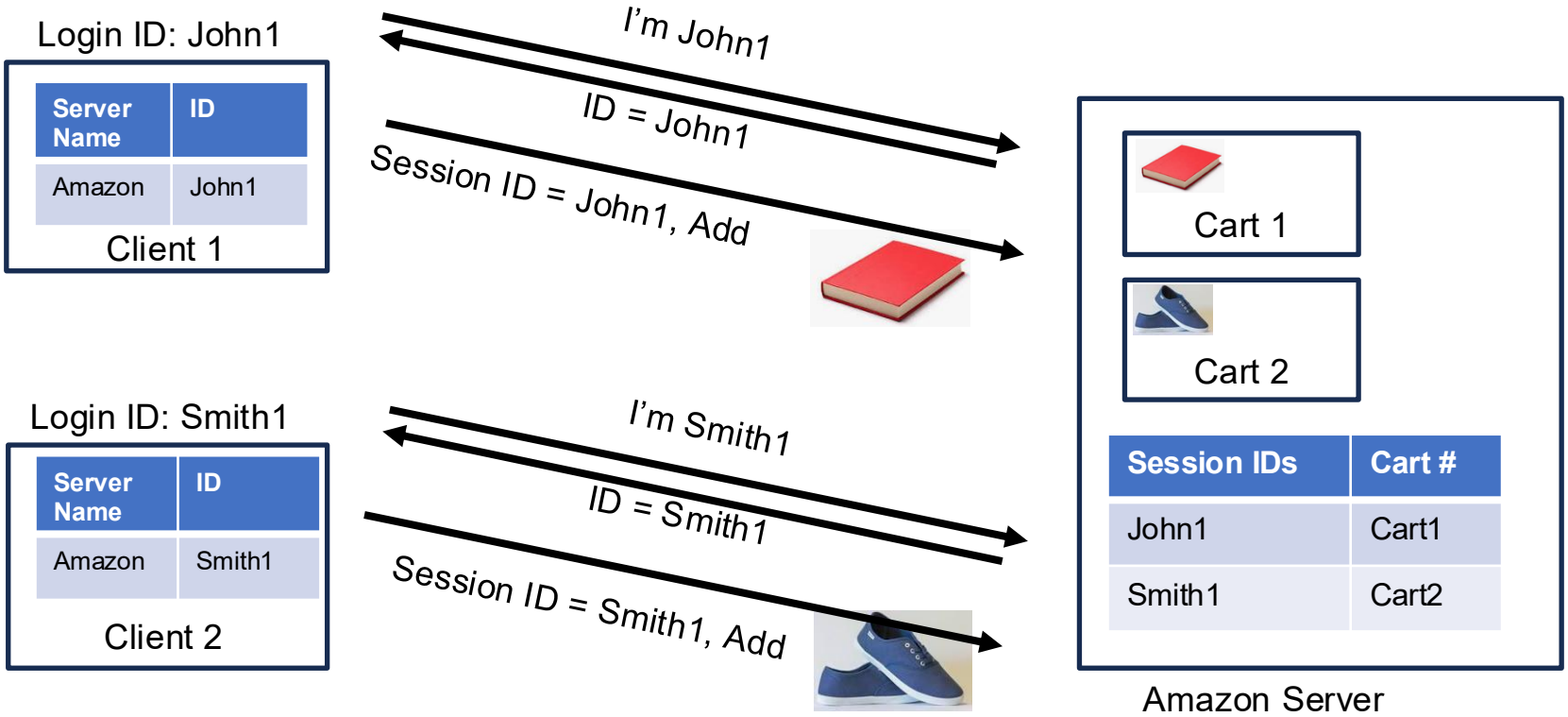
What are sessions?

- How a website knows multiple requests come from the same user



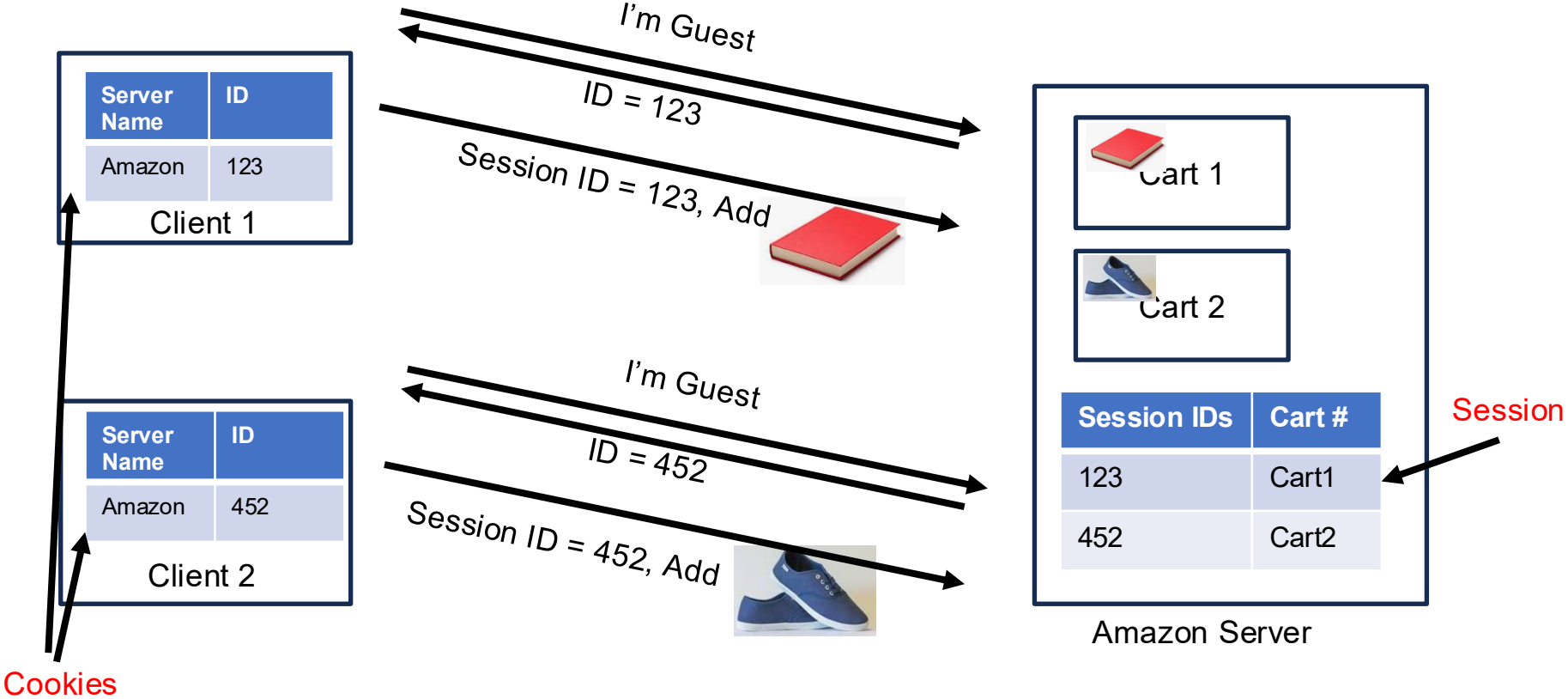
What are sessions?

- How a website knows multiple requests come from the same user



What are sessions?

- How a website knows multiple requests come from the same user



Agenda

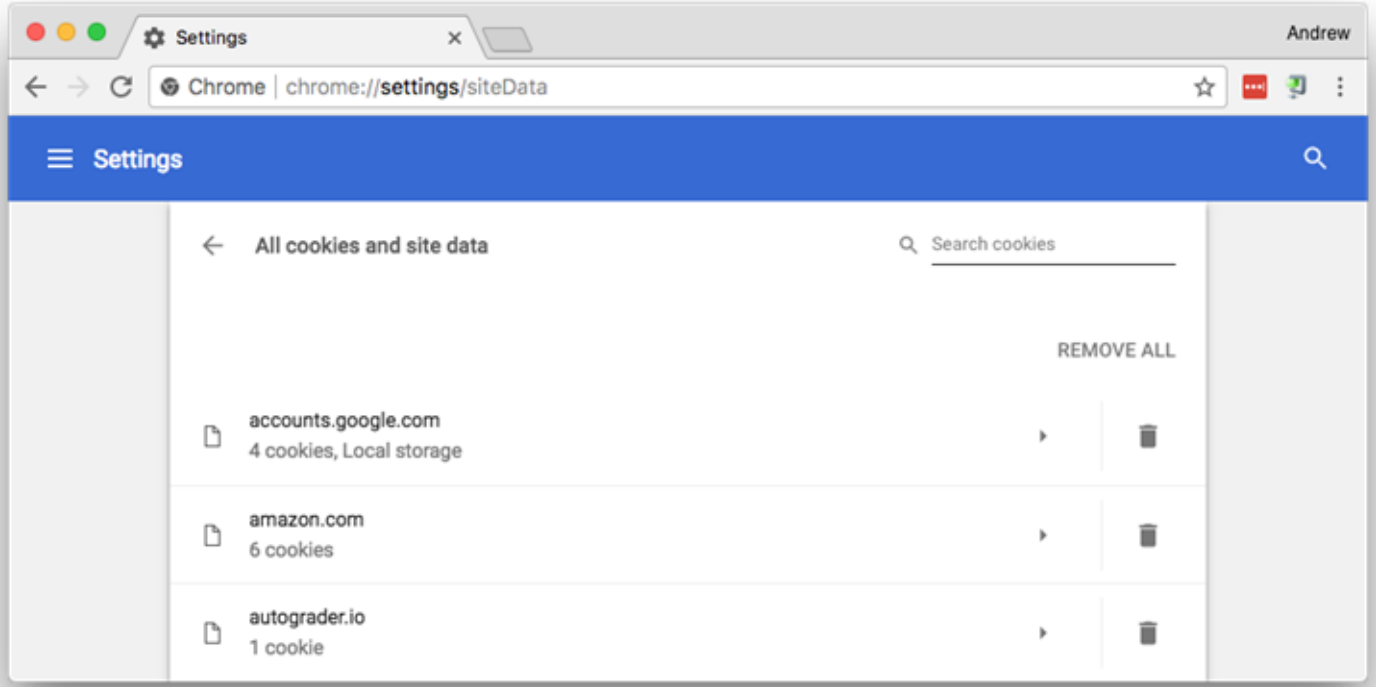
- Sessions
- **First-party cookies**
- Third-party cookies
- Example from project 2

Cookies

- Cookies are small pieces of data stored in the browser
- Carry state between HTTP requests
- Contain key/value pairs

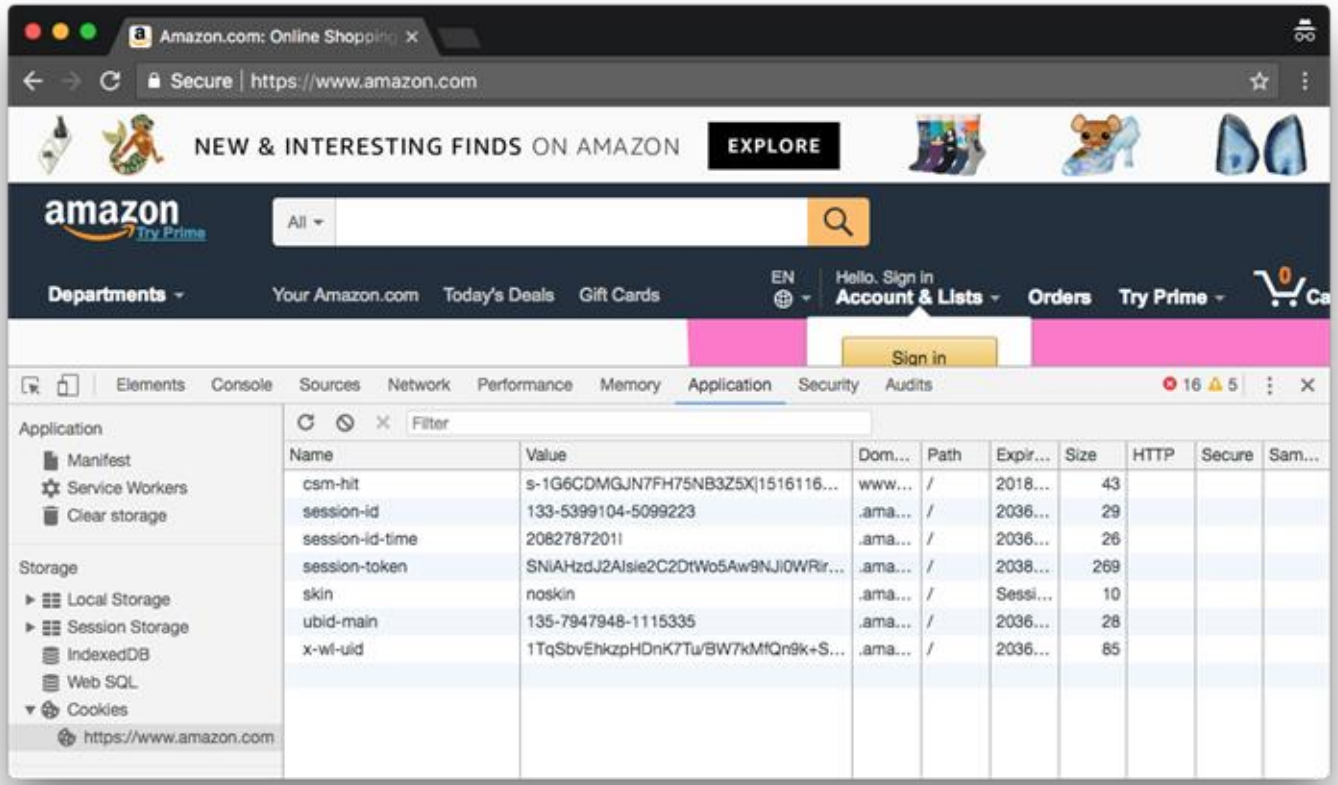
Example: cookies in Chrome

- Browsing to `chrome://settings/siteData`
- You can inspect cookies on your own browser



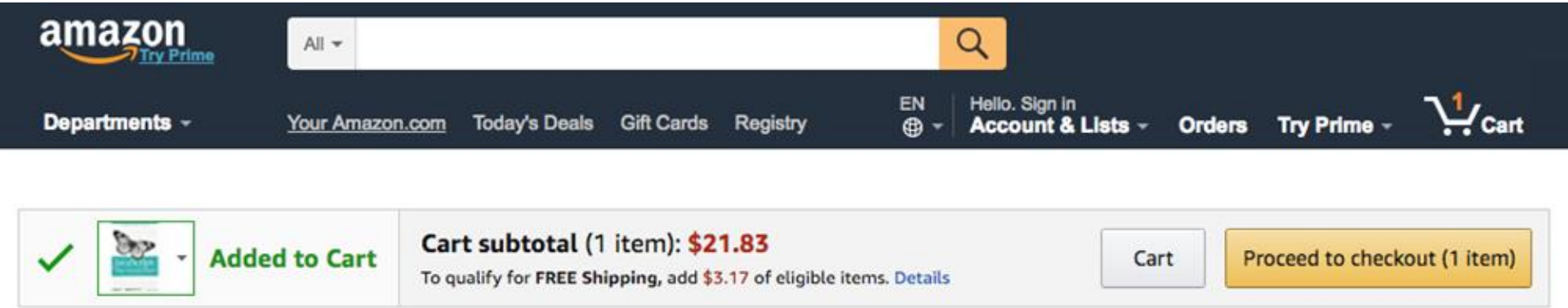
Example: cookies in Chrome

- Browse to https://www.amazon.com/
- Settings / Advanced / Content settings / Cookies / See all cookies



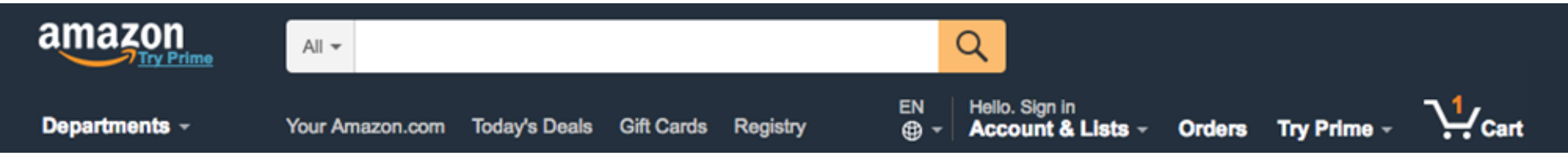
Example: shopping cart

- Browse to https://www.amazon.com/
- Add something to the cart



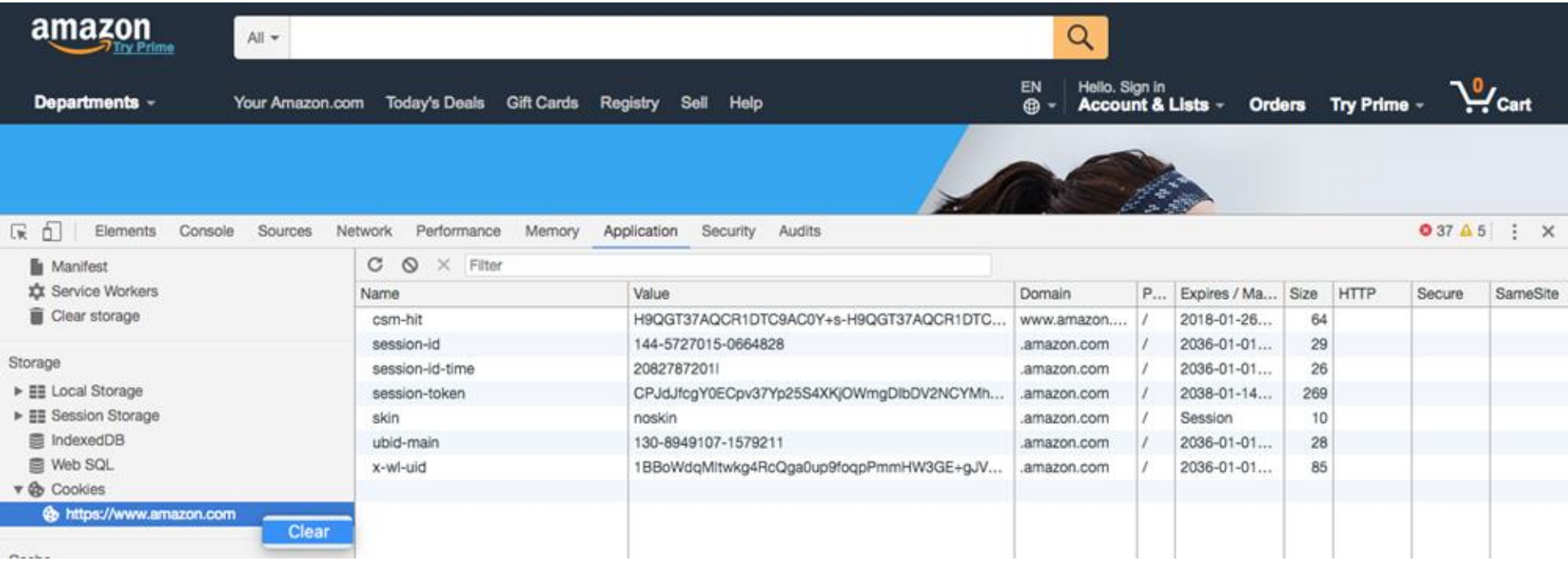
Example: shopping cart

- Again, browse to https://www.amazon.com/
- Cart has one item, even though we're on a different page



Example: shopping cart

- Clear cookies using the developer console

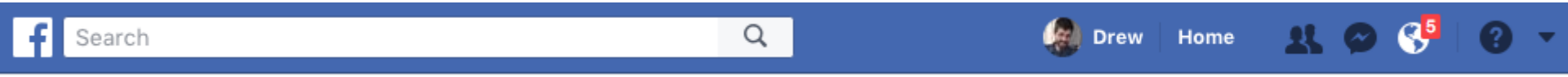


Example: shopping cart

- Again, browse to https://www.amazon.com/
- Cart appears empty because the session cookie is gone

Example: facebook log in

- Log in Facebook (or any other web site)



- Clear the Facebook cookies using the developer console
- Visit facebook.com again
- You're no longer logged in

Cookie content

- **Name:** chosen by the server
- **Value:** chosen by the server (often encrypted)
- **Domain:** which site can read it
- **Path:** specifies scope of cookie
  - / vs. /cart/ or whatever
- **Expiration:** when browser deletes it
- **Secure:** is how cookie may be transmitted

Name	Value	Domain	Path	Expires / Max...	Size	HTTP	Secure	SameSite
csm-hit	6SMS3JE6TN8HC9JXT1BM+s-D02JSKPWCWCEQ1JBFH...	www.amazon.com	/	2018-01-23T...	64			
session-id	133-7499895-4230864	.amazon.com	/	2036-01-01T...	29			
session-id-time	2082787201l	.amazon.com	/	2036-01-01T...	26			
session-token	Z7BBJabdxLhufMLF1UNiZK75ibXyTodM3OuusYgiO7xCgR...	.amazon.com	/	2038-01-11T...	269			
skin	noskin	.amazon.com	/	Session	10			
spblockdate	1516117231080	www.amazon.com	/	2028-01-14T...	24			
ubid-main	132-0740974-0237934	.amazon.com	/	2036-01-01T...	28			
x-wl-uid	1gaw0tztjcgWgcjkDQSl9Hr4AkyB33hIw9lk44qFtLMtimrpn...	.amazon.com	/	2036-01-01T...	85			

Cookie rules

- Cookies only over-writable by same domain and path
- Enforced by browser

- Store a username, session ID, etc. in the cookie
- Use session ID or username to do a database lookup
    - Shopping card content

Cookie transfer

- Set by server
- Sent by client, but never edited
- Either side can delete/ignore cookies

- Sent as part of HTTP headers

Cookie overhead

- Cookies add to HTTP overhead
- Best practice is to store a small amount of data in the cookie
- Use that data to do a database lookup on the server side

Secure (Encrypted) cookie transfer

- If I have your cookies, I can steal your session
  - To the server, I look just like you!
- Prevent this by sending cookies only over HTTPS

Name	Value	Domain	P...	Expires / Max...	Size	HTTP	Secure
a-ogbcbff	1	.amazon.com	/	2018-01-16T...	10		
at-main	Atza|IwEBIL-ZdP_TnX55gVrEdKvscQRM4Tjoq0cTj_bivnQG...	.amazon.com	/	2038-01-11T...	424	✓	✓
aws-ubid-main	102-1422888-1085586	.amazon.com	/	2086-02-03T...	32	✓	✓
csm-hit	s-MZBVZTC3VF120DMVJDF6|1516118415619	www.amazon.com	/	2018-01-23T...	43		
lc-main	en_US	.amazon.com	/	2038-01-11T...	12		
sess-at-main	"bWhsxGV15YSI5RDUGleDQGcU9k+PLNN0MI3JPNsPj28="	.amazon.com	/	Session	58	✓	✓
session-id	142-6976303-8296237	.amazon.com	/	2036-01-01T...	29		
session-id-time	2082787201l	.amazon.com	/	2036-01-01T...	26		
session-token	OCpqc+N1p2eiUvVrZI+3wUqsRi6Fm3I6JnSMhC19oN5kve...	.amazon.com	/	2038-01-11T...	281		
skin	noskin	.amazon.com	/	Session	10		
spblockdate	1514917833143	www.amazon.com	/	2027-12-31T...	24		
sst-main	Sst1|PQGjiLW9hWUjZlPblHPlPXH8CAeBAYdLmz4cPvGgEb...	.amazon.com	/	2038-01-11T...	295	✓	✓
ubid-main	132-7633599-2974057	.amazon.com	/	2036-01-01T...	28		
x-main	"JqL@@cu6yh0xuDwQrAfLeP9PI@9TlcZgRYXh08zDQC7gV...	.amazon.com	/	2038-01-11T...	72		
x-wl-uid	1qpmQHYEzowtwk8DHEWu0Bfr4FGX+O579dYLEygZC8kyj...	.amazon.com	/	2036-01-01T...	149		

Signed or Encrypted cookie values

- If the client has a copy of cookies set by the server, then the client can manipulate the server
- Prevent this with signed or encrypted cookie content
  - Only the server can verify or decrypt

Name	Value	Domain	P...	Expires / Max...	Size	HTTP	Secure
a-ogbcbff	1	.amazon.com	/	2018-01-16T...	10		
at-main	Atza|IwEBIL-ZdP_TnX55gVrEdKvscQRM4Tjoq0cTj_bivnQG...	.amazon.com	/	2038-01-11T...	424	✓	✓
aws-ubid-main	102-1422888-1085586	.amazon.com	/	2086-02-03T...	32	✓	✓
csm-hit	s-MZBVZTC3VF120DMVJDF6|1516118415619	www.amazon.com	/	2018-01-23T...	43		
lc-main	en_US	.amazon.com	/	2038-01-11T...	12		
sess-at-main	"bWhsxGV15YSI5RDUGieDQGcU9k+PLNN0MI3JPNsPj28="	.amazon.com	/	Session	58	✓	✓
session-id	142-6976303-8296237	.amazon.com	/	2036-01-01T...	29		
session-id-time	2082787201l	.amazon.com	/	2036-01-01T...	26		
session-token	OCpqc+N1p2eiUvVrZI+3wUqsRi6Fm3I6JnSMhC19oN5kve...	.amazon.com	/	2038-01-11T...	281		
skin	noskin	.amazon.com	/	Session	10		
spblockdate	1514917833143	www.amazon.com	/	2027-12-31T...	24		
sst-main	Sst1|PQGjiLW9hWUjZIPbIHPIPXH8CAeBAYdLmz4cPvGgEb...	.amazon.com	/	2038-01-11T...	295	✓	✓
ubid-main	132-7633599-2974057	.amazon.com	/	2036-01-01T...	28		
x-main	"JqL@@cu6yh0xuDwQrAfLeP9PI@9TlcZgRYXh08zDQC7gV...	.amazon.com	/	2038-01-11T...	72		
x-wl-uid	1qpmQHYEzowtwk8DHEWu0Bfr4FGX+O579dYLEygZC8kyj...	.amazon.com	/	2036-01-01T...	149		

Agenda

- Sessions
- First-party cookies
- **Third-party cookies**
- Example from project 2

Third-party cookies

- Goal: track a user across different websites
- Useful for advertisers to learn what sites you visit

Where they come from?

- Page can load content from many domains
  - Scripts, images, etc.
- These 3rd-party domains can set and read cookies

- Example: nytimes.com

```
<html>
  <head>
    <script
      src="https://tags.doubleclic.net/site/50550?ret=js&limit=1"
      type="text/javascript"
    >
    </script>
  </head>
  <body>
    <img src="https://static01.nyt.com/images/lindsey-graham.png">
  </body>
</html>
```

Cookie domains

- Cookies always belong to a domain
- ***First-party cookie***: same domain as the page you are on
- ***Third-party cookie***: different domain

- Example from nytimes.com

Name	Value	Domain	P...	Expires / Ma...	Size	HTTP	Secure	SameSite
IDE	AHWqTUle_KCiqXNrNt3LWAFbPHlkNNCKdka6oVRxF...	.doubleclick.net	/	2020-01-16...	67	✓		
UID	15718486a24320a1606e8cg1516118895	.scorecardres...	/	2020-01-06...	36			
UIDR	1516118895	.scorecardres...	/	2020-01-06...	14			
__gads	ID=a2a38e066efb072b:T=1516118895:S=ALNI_MYy9...	.nytimes.com	/	2020-01-16...	75			
__utma	69104142.228179094.1516118895.1516118895.15161...	.nytimes.com	/	2020-01-16...	59			
__utmb	69104142.1.10.1516118896	.nytimes.com	/	2018-01-16...	30			
__utmc	69104142	.nytimes.com	/	Session	14			
__utmt	1	.nytimes.com	/	2018-01-16...	7			
__utmz	69104142.1516118896.1.1.utmcsr=(direct)|utmccn=(di...	.nytimes.com	/	2018-07-18...	75			

Example: Google advertising cookies

- Advertising cookie name `IDE` and is stored under the domain `doubleclick.net`.
- Set when visiting many non-Google websites
  - https://www.google.com/policies/technologies/types/

- Example: visit nytimes.com and view cookies:

Name	Value	Domain	P...	Expires / Ma...	Size	HTTP	Secure	SameSite
IDE	AHWqTUle_KCiqXNrNt3LWAFbPHlkNNCKdka6oVRxF...	.doubleclick.net	/	2020-01-16...	67	✓		
UID	15718486a24320a1606e8cg1516118895	.scorecardres...	/	2020-01-06...	36			
UIDR	1516118895	.scorecardres...	/	2020-01-06...	14			
__gads	ID=a2a38e066efb072b:T=1516118895:S=ALNI_MYy9...	.nytimes.com	/	2020-01-16...	75			
__utma	69104142.228179094.1516118895.1516118895.15161...	.nytimes.com	/	2020-01-16...	59			
__utmb	69104142.1.10.1516118896	.nytimes.com	/	2018-01-16...	30			
__utmc	69104142	.nytimes.com	/	Session	14			
__utmt	1	.nytimes.com	/	2018-01-16...	7			
__utmz	69104142.1516118896.1.1.utmcsr=(direct)|utmccn=(di...	.nytimes.com	/	2018-07-18...	75			

Example: Google advertising cookies

- Excerpt from nytimes.com HTML source

```
<html>
  <body>
    ...
    <script>
     function placeGpt() {
       var gptScript = document.createElement('script');
       gptScript.src = '//securepubads.g.doubleclick.net/tag/js/gpt.js';
       document.head.appendChild(gptScript);
     }
     placeGpt()
    </script>
  </body>
</html>
```

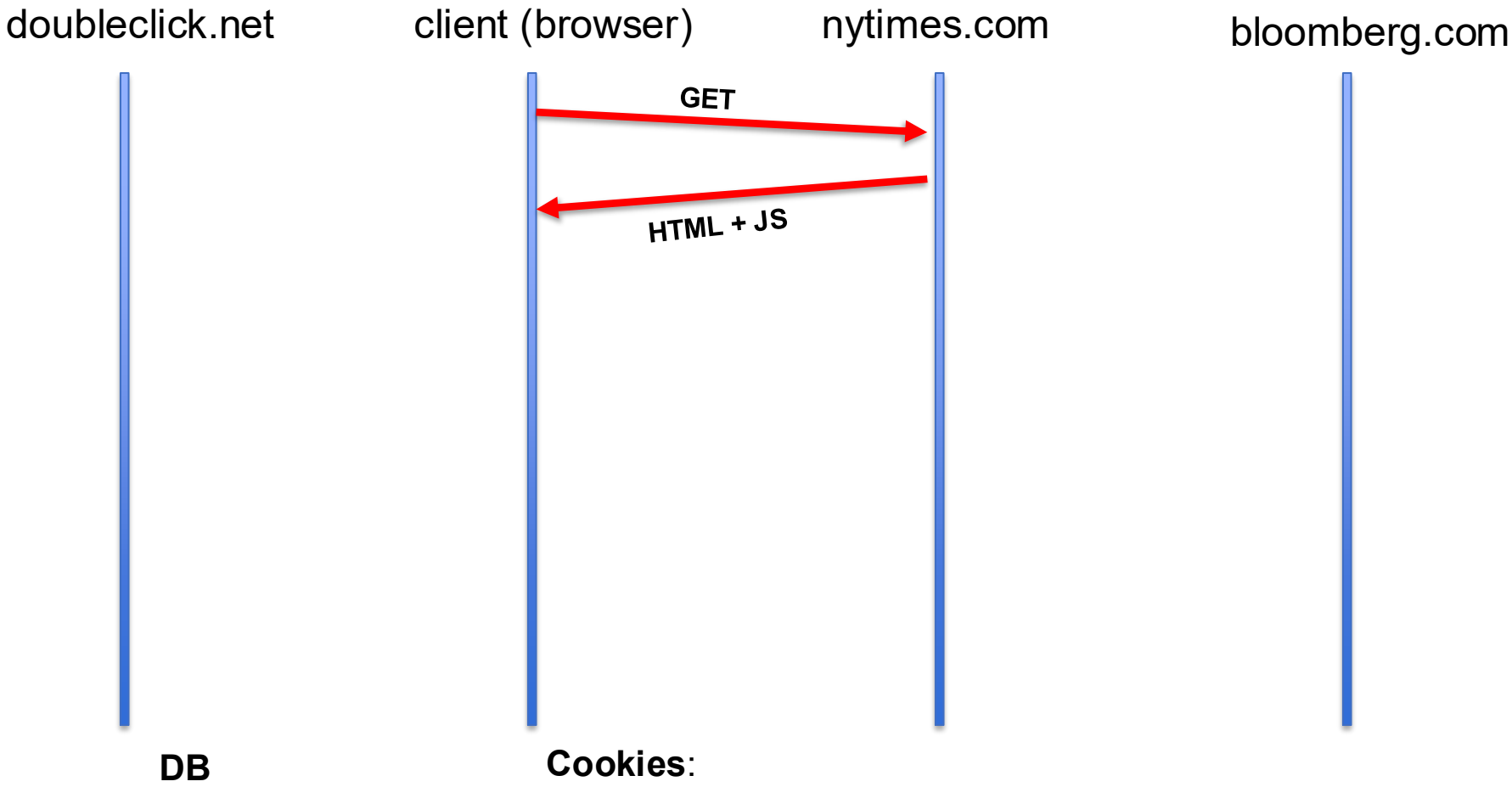
Example: First Visit flow (nytimes.com)

- You visit **nytimes.com**
- Browser gets HTML + JavaScript
- JavaScript sends request to doubleclick.net
- Request includes current site (nytimes.com)
- doubleclick.net creates a unique ID
- Server responds with Set-Cookie for doubleclick.net

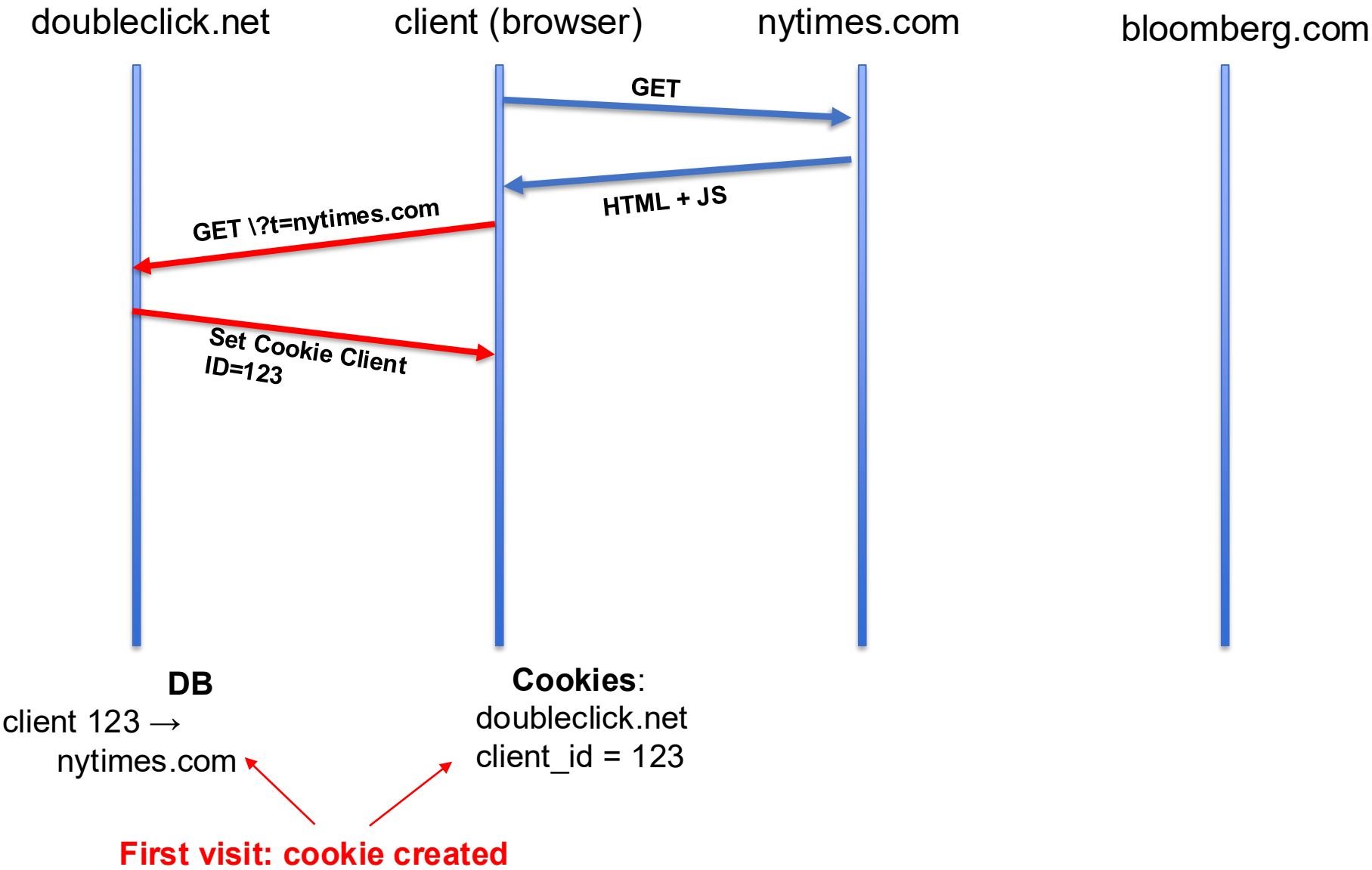
Example: Second visit flow (bloomberg.com)

- You visit **bloomberg.com**
- Page loads JavaScript from doubleclick.net
- Browser sends request to doubleclick.net
    - Includes existing cookie (your ID)
    - Includes current site (bloomberg.com)
- doubleclick.net recognizes you
- Database updated with new site visit

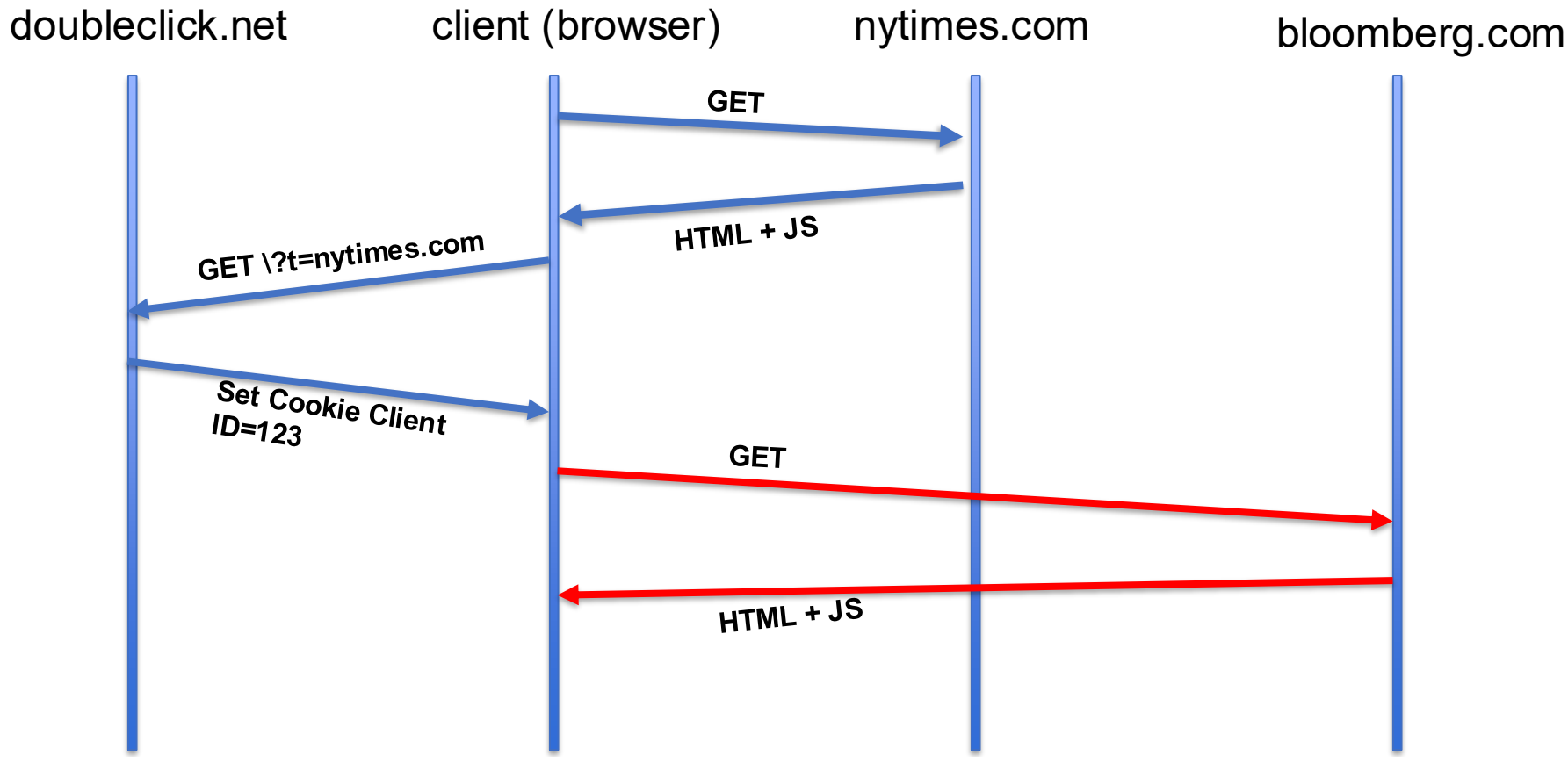
Example: Google advertising Cookies



Example: Google advertising Cookies



Example: Google advertising Cookies

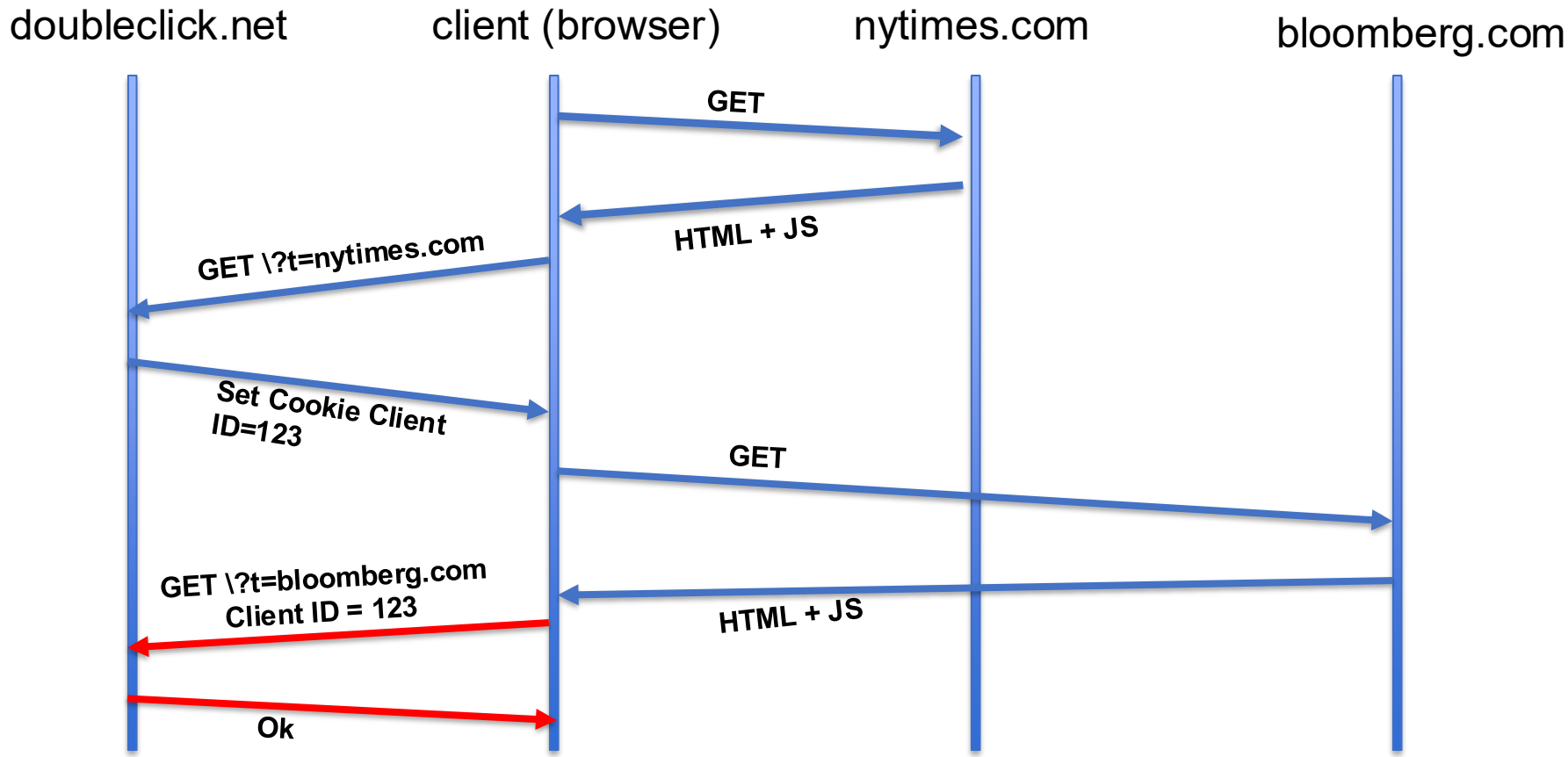


DB

client 123 →
nytimes.com

Cookies:
doubleclick.net
client_id = 123

Example: Google advertising Cookies



DB

client 123 →
nytimes.com
bloomberg.com

Cookies:
doubleclick.net
client_id = 123

Second site: same cookie reused

Who uses third-party cookies?

- Companies that sell ads directly
  - Google and Facebook (obviously)
- Companies that sell information about you
  - Acxiom "one of the biggest companies you've never heard of" ($1B+)
- “If you're not paying for the product, then you *are* the product”
  - That's mostly how the business side of the web is structured

Agenda

- Sessions
- First-party Cookies
- Third-party cookies
- **Example from project 2**

Cookie example

Key idea: cookie is a collection of key/value pairs. Flask provides them in a dictionary called `flask.session`

```
if "user" in flask.session:
        user = flask.session["user"]
else:
        flask.session["user"] = "smith"
```

Test if key exists

Get key/value

Set key/value

Cookie example

Key idea: cookie is a collection of key/value pairs. Flask provides them in a dictionary called `flask.session`

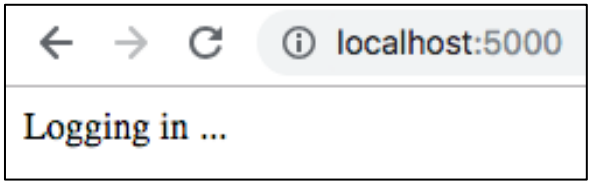
```
import flask
app = flask.Flask(__name__)

app.secret_key = b'…secure random bytes…'

@app.route('/')
def index():
    if "user" in flask.session:
        user = flask.session["user"]
        return "<html><body>Hello {user}</body></html>"
    else:
        flask.session["user"] = "smith"
        return "<html><body>Logging in ...</body></html>"

if __name__ == '__main__':
    app.run()
```

Run the cookie example

- Start server

```
$ python3 test.py
```

- Browse to http://localhost:5000/



- See encrypted cookie in developer console

Cookie encryption key

- Goal: prevent users from forging session cookies

- The encryption key must be:
  - Random
  - Unpredictable
  - Cryptographically secure.

- Generate a Python string

```
$ python3 -c "import os; print(os.urandom(24))"
```

```
b'uAy\x9d\x08[\x12\x8d\x9d\x1f\xbar\x86A\x9fpQy4\x05)v04'
```

Cookie example

Key idea: cookie is a collection of key/value pairs. Flask provides them in a dictionary called `flask.session`

```
import flask
app = flask.Flask(__name__)

app.secret_key = b'uAy\x9d\x08[\x12\x8d\x9d\x1f\xbar\x86A\x9fpQy4\x05)v04'

@app.route('/')
def index():
    if "user" in flask.session:
        user = flask.session["user"]
        return f"<html><body>Hello {user}</body></html>"
    else:
        flask.session["user"] = "smith"
        return "<html><body>Logging in ...</body></html>"

if __name__ == '__main__':
    app.run()
```

Test if key exists

Get key/value

Set key/value

Cookie encryption key

```
import flask
app = flask.Flask(__name__)

app.secret_key = b'uAy\x9d\x08[\x12\x8d\x9d\x1f\xbar\x86A\x9fpQy4\x05)v04'

# ...
```

- Session cookies are **encrypted**
- Ony the server knows the encryption key
- Without encryption, anyone could pretend to be any one

Summary

- A *session* helps a server tell the difference between clients
- Sessions are implemented with *cookies*
- Cookies are set by one site's server and stored by the client's browser
- Site's cookies are sent by the client with every request to the site
- *Third-party cookies* are used for tracking users across different sites

Further reading

- Good reference on first-party cookies

https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies

- Good reference on third-party

https://developer.mozilla.org/en-US/docs/Web/Privacy/Third-party_cookies